

GTU Exam Questions - Solved

Cryptography and Web Security (DI03016021) - GTU Diploma IT Sem 3
Winter 2025 + Summer 2026 papers

What this PDF is: every question from the two GTU papers that exist for this new subject (Winter 2025 and Summer 2026), solved in exam-ready form. Each paper is for **70 marks** = 5 questions; every question has (a) 3 marks, (b) 4 marks, (c) 7 marks, and each part has an **OR** alternative - so you answer 15 parts and skip 15.

PRIORITY 1: Topics that came in BOTH papers (study these first)

With only two papers, a topic that appeared in both is the safest bet to appear again. It is not a guarantee, so still read the other topics.

Topic	Winter 2025	Summer 2026
CIA	Q1(a) (3M)	Q2(a) (3M)
Additive cipher	Q1(b) (4M)	Q3(a) OR (3M)
Euclidean GCD	Q1(c) (7M)	Q2(c) OR (7M)
Extended Euclidean	Q1(c) OR (7M)	Q2(c) (7M)
Network security model	Q2(b) (4M)	Q1(c) OR (7M)
Modular arithmetic	Q2(a) OR (3M)	Q2(b) (4M)
Zn and Zn*	Q2(b) OR (4M)	Q2(b) OR (4M)
Security attacks	Q2(c) OR (7M)	Q1(c) (7M)
Hill cipher	Q3(c) (7M)	Q3(b) OR (4M)
Keyed transposition	Q3(a) OR (3M)	Q3(c) (7M)
RSA	Q3(c) OR (7M)	Q3(c) OR (7M)
Web security threats	Q4(a) (3M)	Q4(a) (3M)
SSL protocol stack	Q4(b) (4M)	Q4(b) (4M)
SET	Q4(c) (7M)	Q4(c) OR (7M)
Web security approaches	Q4(a) OR (3M)	Q5(a) (3M)
HTTPS	Q4(b) OR (4M)	Q4(c) (7M)
SSL vs SET	Q4(c) OR (7M)	Q5(a) OR (3M)
Firewall	Q5(b) (4M)	Q5(c) OR (7M)
IDS	Q5(c) (7M)	Q5(b) (4M), Q5(b) OR (4M)
Firewall types	Q5(c) OR (7M)	Q5(c) (7M)

PRIORITY 2: Asked once (also important)

- Explain divisibility and division algorithm - W2025 Q2(a)

- Explain six security services in detail - W2025 Q2(c)
- Explain stream cipher and block cipher with example - W2025 Q3(a)
- Explain working of Autokey cipher with example - W2025 Q3(b)
- Encrypt "battery" using Playfair cipher - W2025 Q3(b) OR
- If the key is 11 and its multiplicative inverse key = 19, decrypt the - W2025 Q5(a)
- Explain the categories of the intruders in the system security - W2025 Q5(a) OR
- Explain the working of one-time pad algorithm with example - W2025 Q5(b) OR
- Define cryptography and cryptanalysis - S2026 Q1(a)
- Differentiate between substitution and transposition technique with ex - S2026 Q1(b)
- State any three security mechanisms - S2026 Q2(a) OR
- Apply Vigenère cipher to encrypt "KEEP MESSAGE SECRET" using key = CIP - S2026 Q3(a)
- Perform encryption and decryption of plaintext "HELLO" using Affine ci - S2026 Q3(b)
- State functions of TLS record and TLS alert protocols - S2026 Q4(a) OR
- Differentiate SSL vs TLS - S2026 Q4(b) OR

Unit-wise marks pattern (from syllabus weightage)

Unit	Weightage	Expected marks out of 70
1 Intro to Network Security	18%	≈ 12-13
2 Number Theory	16%	≈ 11
3 Classical Encryption (incl. RSA)	26%	≈ 18
4 Web Security	24%	≈ 17
5 System Security	16%	≈ 11

Note: Unit 3 and Unit 4 together are about half of the paper. Numericals (Euclid, Extended Euclid, ciphers, Hill, RSA) give the easiest full marks - practise them by hand.

Solved paper - Winter 2025 (06-12-2025)

Q1(a) [3 marks] With reference to computer security, explain confidentiality, integrity and availability.

★ Repeated topic - also asked in Summer 2026: Q2(a) (3M)

CIA triad = the three main goals of computer security.

Goal	Meaning (simple)	Example	How we get it
Confidentiality	Only authorised people can read the information. Keep it secret.	ATM PIN, encrypted chat	Encryption, passwords
Integrity	Information is not changed by unauthorised people. Keep it the same.	Hacker changes Rs.1,000 to Rs.10,000 in a bank record = integrity lost	Hash, digital signature, checksum
Availability	Data and services are available whenever authorised users need them. Keep it running.	Website crashing due to a DoS attack = availability lost	Backup, redundancy, firewall

Two extra requirements (for 4-7 marks):

- **Authenticity** - the message/user is genuine and can be verified (it really came from who it says).
- **Accountability** - every action can be traced to the person who did it (logs), so nobody can deny it later.

Easy way to remember: Confidentiality = **Secret**, Integrity = **Same (unchanged)**, Availability = **Always on**.

Q1(b) [4 marks] Encrypt the plain-text "transform" using Additive cipher, key 9. Show the modular arithmetic calculation.

★ Repeated topic - also asked in Summer 2026: Q3(a) OR (3M)

Additive cipher (Caesar / shift cipher): letters are numbered **a=0, b=1 ... z=25**. Key K is added to each letter, everything mod 26.

Encryption: $C = (P + K) \bmod 26$ Decryption: $P = (C - K) \bmod 26$

Key space is only 26 (25 useful keys), so it is easily broken by **brute force** - try all 25 keys. Caesar cipher is the case $K = 3$.

Solved (W2025): plaintext "transform", key = 9

Plain letter	T	R	A	N	S	F	O	R	M
P (number)	19	17	0	13	18	5	14	17	12
$(P + 9) \bmod 26$	2	0	9	22	1	14	23	0	21
Cipher letter	C	A	J	W	B	O	X	A	V

Ciphertext = CAJWBOXAV

Example of one step: $t = 19 \rightarrow (19 + 9) \bmod 26 = 28 \bmod 26 = 2 \rightarrow C$. For $r = 17$: $(17+9) = 26 \bmod 26 = 0 \rightarrow A$.

Q1(c) [7 marks] Write the Euclidean algorithm. Find GCD of 1064 and 940 using the algorithm, in tabular format (q, r1, r2, r).

★ Repeated topic - also asked in Summer 2026: Q2(c) OR (7M)

Euclidean algorithm finds the **GCD** (greatest common divisor) of two numbers. Idea: $\text{gcd}(a, b) = \text{gcd}(b, a \bmod b)$; keep going until the remainder is 0.

Algorithm

1. Take $a > b$. Set $r1 = a, r2 = b$.
2. While $r2 > 0$: $q = r1 \div r2$ (integer division); $r = r1 - q \times r2$; then set $r1 = r2$ and $r2 = r$.
3. When $r2$ becomes 0, $\text{gcd}(a, b) = r1$.

```
r1 = a; r2 = b
while r2 > 0:
    q = r1 // r2
    r = r1 - q * r2
    r1 = r2
    r2 = r
gcd = r1
```

Solved: GCD(1064, 940)

q	r1	r2	r
1	1064	940	124
7	940	124	72
1	124	72	52
1	72	52	20
2	52	20	12
1	20	12	8
1	12	8	4
2	8	4	0

When $r2 = 0$, $r1 = 4$. **GCD(1064, 940) = 4.**

Q1(c) OR [7 marks] Write extended Euclidean algorithm. Find the multiplicative inverse of 19 in Z_{35} in tabular format.

★ Repeated topic - also asked in Summer 2026: Q2(c) (7M)

Extended Euclidean algorithm finds the GCD and the **multiplicative inverse** of b in Z_n . (The paper's s-columns are the 't' columns of the book.)

Algorithm (to find inverse of b in Z_n)

1. Set $r1 = n, r2 = b, s1 = 0, s2 = 1$.
2. While $r2 > 0$: $q = r1 \div r2$; $r = r1 - q \times r2$; $s = s1 - q \times s2$; then shift: $r1 = r2, r2 = r, s1 = s2, s2 = s$.
3. When $r2 = 0$: if $r1 = 1$ the inverse exists and **inverse = $s1 \bmod n$** . If $r1 \neq 1$, no inverse exists.

```
r1, r2 = n, b ; s1, s2 = 0, 1
while r2 > 0:
    q = r1 // r2
    r, s = r1 - q*r2, s1 - q*s2
    r1, r2, s1, s2 = r2, r, s2, s
if r1 == 1: inverse = s1 % n
```

Solved: multiplicative inverse of 19 in Z_{35} ($n = 35, b = 19$)

q	r1	r2	r	s1	s2	s
1	35	19	16	0	1	-1
1	19	16	3	1	-1	2
5	16	3	1	-1	2	-11
3	3	1	0	2	-11	35

$r1 = 1$, so the inverse exists. $s1 = -11$, so inverse = $-11 \bmod 35 = 24$.

Check: $19 \times 24 = 456 = 13 \times 35 + 1 \rightarrow 456 \bmod 35 = 1 \checkmark$

Q2(a) [3 marks] Explain divisibility and division algorithm.

- **Divisibility:** an integer **a** is divisible by **b** (written $b \mid a$) if $a = b \times k$ for some integer k , i.e. the remainder is zero. *Example:* $12 = 3 \times 4$, so $3 \mid 12$.

Properties: if $a \mid b$ and $b \mid c$ then $a \mid c$; if $a \mid b$ and $a \mid c$ then $a \mid (m \cdot b + n \cdot c)$; if $a \mid b$ and $b \mid a$ then $a = \pm b$.

- **Division algorithm:** for any integer **a** and positive integer **n**, there are **unique** integers q (quotient) and r (remainder) such that

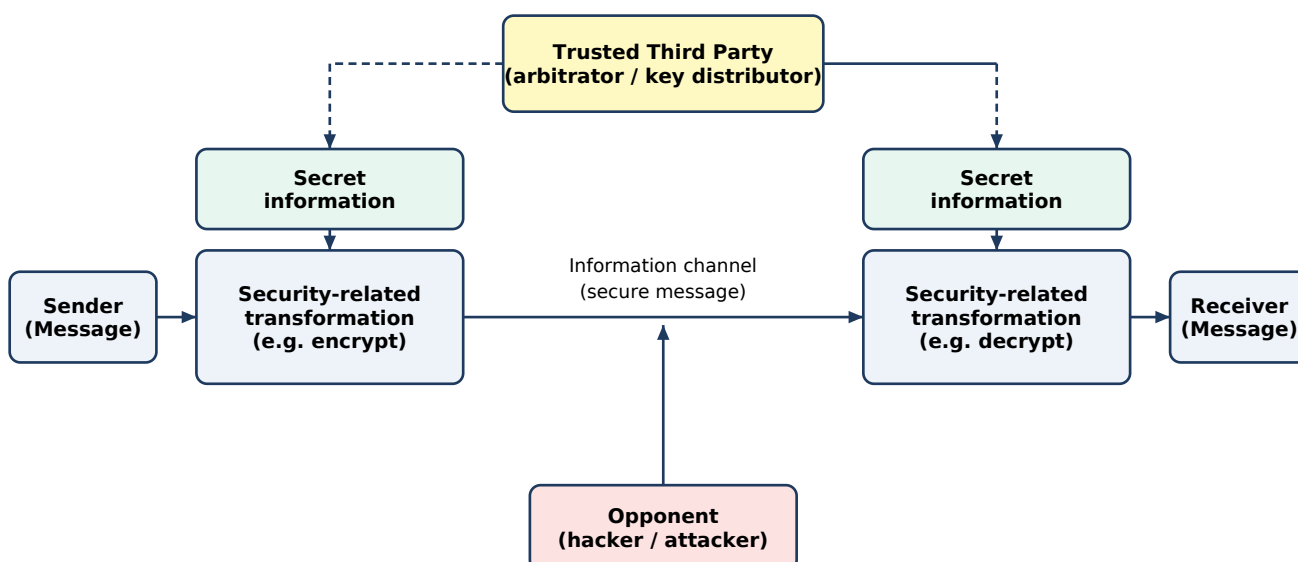
$$a = q \times n + r \quad \text{where } 0 \leq r < n$$

Examples: $17 = 3 \times 5 + 2$ ($q = 3, r = 2$). $-7 = (-3) \times 3 + 2$ ($q = -3, r = 2$). The remainder is never negative.

Q2(b) [4 marks] Draw the model for network security and explain.

★ Repeated topic - also asked in Summer 2026: Q1(c) OR (7M)

How much to write: For 4 marks: diagram + the explanation bullets. The four design tasks are optional.



Explanation: A message must travel from the **sender** to the **receiver** over an **information channel** (internet). An **opponent** may attack this channel. So a **security-related transformation** is applied:

- At the sender: the message is transformed (e.g. **encrypted**) using **secret information** (a key), so it becomes unreadable for the opponent.
- At the receiver: the reverse transformation (e.g. **decryption**) is done using the secret information to get the original message.
- A **trusted third party** may be needed to distribute the secret information (keys) or to settle disputes between sender and receiver.

Four tasks while designing a security service (for 7 marks)

1. Design an **algorithm** for the security transformation that is hard for an opponent to break.
2. **Generate the secret information** (keys) to be used with the algorithm.
3. Develop methods for **distribution and sharing** of the secret information.
4. Specify a **protocol** that uses the algorithm and secret information to provide the security service.

Exam tip: 4 marks: diagram + 3-4 lines. 7 marks: diagram + explanation + the four design tasks.

Q2(c) [7 marks] Explain six security services in detail.

A **security service** is what a system provides to protect data. X.800 defines these six:

Service	What it does	Example
1. Authentication	Confirms that the user/message is genuine. Two types: <i>peer-entity</i> (who is on the other side) and <i>data-origin</i> (who sent this data).	Login with ID + password / OTP
2. Access control	Decides <i>who</i> can use <i>which</i> resource and what they can do with it (read, write, delete).	Student can read marks, only teacher can edit
3. Data confidentiality	Protects data from unauthorised reading. Types: connection, connectionless, selective-field, traffic-flow confidentiality.	Encrypting an email or file
4. Data integrity	Makes sure data is received exactly as sent - no change, insertion, deletion or replay.	Hash/checksum of a downloaded file
5. Nonrepudiation	Sender cannot deny sending and receiver cannot deny receiving. Origin and destination types.	Digital signature on an online contract
6. Availability service	Keeps resources usable when authorised users need them, even under attack.	Backup servers, firewall against DoS

Easy way to remember: A-A-C-I-N-A: Authentication, Access control, Confidentiality, Integrity, Nonrepudiation, Availability.

Q2(a) OR [3 marks] If $a = 12$, $b = 11$ and $n = 7$ then prove that $(a \times b) \bmod n = [(a \bmod n) \times (b \bmod n)] \bmod n$.

★ Repeated topic - also asked in Summer 2026: Q2(b) (4M)

How much to write: Write only the proof part (LHS, RHS, 'hence proved') for 3 marks.

Modulo operator: $a \bmod n$ gives the **remainder** when a is divided by n . Example: $17 \bmod 5 = 2$. If $a \bmod n = b \bmod n$ we write $a \equiv b \pmod{n}$.

Three properties (use any numbers - here $a = 12$, $b = 11$, $n = 7$)

Property	Left side	Right side	Result
Addition: $(a + b) \bmod n = [(a \bmod n) + (b \bmod n)] \bmod n$	$23 \bmod 7 = 2$	$(5 + 4) \bmod 7 = 9 \bmod 7 = 2$	Equal ✓
Subtraction: $(a - b) \bmod n = [(a \bmod n) - (b \bmod n)] \bmod n$	$1 \bmod 7 = 1$	$(5 - 4) \bmod 7 = 1$	Equal ✓
Multiplication: $(a \times b) \bmod n = [(a \bmod n) \times (b \bmod n)] \bmod n$	$132 \bmod 7 = 6$	$(5 \times 4) \bmod 7 = 20 \bmod 7 = 6$	Equal ✓

Prove: $a = 12$, $b = 11$, $n = 7 \rightarrow (a \times b) \bmod n = [(a \bmod n) \times (b \bmod n)] \bmod n$

LHS: $(12 \times 11) \bmod 7 = 132 \bmod 7$. Since $132 = 18 \times 7 + 6$, LHS = 6.

RHS: $12 \bmod 7 = 5$ and $11 \bmod 7 = 4$. So $[(5) \times (4)] \bmod 7 = 20 \bmod 7 = 6$ (because $20 = 2 \times 7 + 6$).

LHS = RHS = 6. **Hence proved.**

General reason: write $a = n \cdot q_1 + r_1$ and $b = n \cdot q_2 + r_2$. Then $a \times b = n(\dots) + r_1 \times r_2$, so $a \times b$ leaves the same remainder as $r_1 \times r_2$.

Q2(b) OR [4 marks] Explain the sets Z_n and Z_n^* . Provide the members of Z_7 and Z_7^* .

★ Repeated topic - also asked in Summer 2026: Q2(b) OR (4M)

How much to write: For 4 marks the first two bullets + Z_7 members + the inverse table are enough.

- **Z_n (set of residues):** all possible remainders when dividing by n . $Z_n = \{0, 1, 2, \dots, n-1\}$.
 $Z_7 = \{0, 1, 2, 3, 4, 5, 6\}$.
- **Z_n^* (set of multiplicative inverses):** only those members of Z_n which have a multiplicative inverse, i.e. numbers with $\gcd(a, n) = 1$ (co-prime to n). Zero is never in Z_n^* .
- **$Z_7^* = \{1, 2, 3, 4, 5, 6\}$** (7 is prime, so every non-zero number is co-prime to 7).
- Another example: **$Z_{10}^* = \{1, 3, 7, 9\}$** (2, 4, 5, 6, 8 share a factor with 10).

Inverses

- **Additive inverse** of a : the number b such that $a + b \equiv 0 \pmod{n}$. Every member of Z_n has one.
- **Multiplicative inverse** of a : the number b such that $a \times b \equiv 1 \pmod{n}$. Exists only if $\gcd(a, n) = 1$.

Z_7 member	0	1	2	3	4	5	6
Additive inverse	0	6	5	4	3	2	1
Multiplicative inverse	–	1	4	5	2	3	6

Check: $3 \times 5 = 15 = 2 \times 7 + 1 \rightarrow 3$ and 5 are multiplicative inverses in Z_7 . Z_7 and Z_7^* differ only by the number 0.

Addition and multiplication tables of Z_5 (syllabus 2.3.3)

Addition table of Z_5

+	0	1	2	3	4
0	0	1	2	3	4
1	1	2	3	4	0
2	2	3	4	0	1
3	3	4	0	1	2
4	4	0	1	2	3

Multiplication table of Z_5

×	0	1	2	3	4
0	0	0	0	0	0
1	0	1	2	3	4
2	0	2	4	1	3
3	0	3	1	4	2
4	0	4	3	2	1

In the addition table, 0 appears in every row/column (so every number has an additive inverse). In the multiplication table, 1 appears in every non-zero row (so every non-zero number has a multiplicative inverse).

Q2(c) OR [7 marks] Explain two passive and four active attacks of network security.

★ Repeated topic - also asked in Summer 2026: Q1(c) (7M)

Security Attacks

PASSIVE attacks
Release of message contents
Traffic analysis

ACTIVE attacks
Masquerade | Replay
Modification | Denial of Service

A) Passive attacks - attacker only watches, does not change anything

- **Release of message contents:** attacker reads (eavesdrops) an email, phone call or file.
Example: sniffing an unencrypted Wi-Fi password.
- **Traffic analysis:** even if the message is encrypted, attacker studies the pattern - who talks to whom, how often, message length - and guesses useful information.

Passive attacks are **very hard to detect** (nothing changes) but **can be prevented** by encryption.

B) Active attacks - attacker changes data or disturbs the system

- **Masquerade:** one entity pretends to be another. *Example: using a stolen password to log in as someone else.*
- **Replay:** attacker captures a valid message and sends it again later to get an unauthorised effect. *Example: re-sending a captured 'transfer Rs.5,000' request.*
- **Modification of messages:** part of a genuine message is altered, delayed or reordered.
Example: 'Pay Rs.100 to A' changed to 'Pay Rs.900 to B'.
- **Denial of Service (DoS):** attacker floods a server or network so genuine users cannot use it.
Example: millions of fake requests crash a website.

Active attacks are **easy to detect** but **hard to prevent completely** - so we try to detect and recover.

Point	Passive attack	Active attack
Data	Not altered	Altered or created
Goal	Learn information	Damage / change / disturb
Detection	Very difficult	Easier
Prevention	Possible (encryption)	Difficult (detect + recover)
Threatens	Confidentiality	Integrity, Availability, Authenticity

Exam tip: For '7 marks' draw the classification diagram, write 2 passive + 4 active with one example each, and add the comparison table.

Q3(a) [3 marks] Explain stream cipher and block cipher with example.

Point	Stream cipher	Block cipher
Processing	Encrypts one bit / one byte at a time with a keystream (usually XOR)	Encrypts a fixed-size block (e.g. 64 or 128 bits) at a time
Speed / use	Fast, good for real-time data (voice, video, Wi-Fi)	Slower, good for files and bulk data
Error effect	A bit error affects only that bit	An error can affect the whole block
Key	Key stream generated from a key (one-time pad is the ideal stream cipher)	Same key used for each block
Examples	RC4, one-time pad, Vigenère (letter by letter)	DES (64-bit), AES (128-bit), Hill cipher, Playfair (pairs)

Q3(b) [4 marks] Explain working of Autokey cipher with example.

Autokey cipher is a polyalphabetic cipher. The key is **one starting key + the plaintext itself**. So the key stream never repeats, which makes it stronger than Vigenère.

Encryption: $C_i = (P_i + k_i) \bmod 26$, where $k_1 =$ given key and $k_i = P_{i-1}$ for $i > 1$.

Example: plaintext HELLO, key = 7 (letter H)

Plain letter	H	E	L	L	O
P	7	4	11	11	14
Key stream	7	7	4	11	11
(P + key) mod 26	14	11	15	22	25
Cipher letter	O	L	P	W	Z

Key stream = 7, then H(7), E(4), L(11), L(11). **Ciphertext = OLPWZ.**

Decryption: $P = (C - k) \bmod 26$. First letter uses the given key; each decrypted plaintext letter becomes the next key. $O - 7 = 7 = H$; then $L - H(7) = 11 - 7 = 4 = E$; and so on.

Weakness: the key stream contains the plaintext, so attacks guessing words are possible; if the key is a single letter there are only 25 keys.

Q3(c) [7 marks] Convert plain-text "decisions" into cipher-text using Hill cipher, key matrix $[[5,7,10],[3,1,7],[0,5,2]]$. Show all steps.

★ Repeated topic - also asked in Summer 2026: Q3(b) OR (4M)

Hill cipher: polyalphabetic cipher that encrypts a **block of letters** at once using **matrix multiplication** mod 26 ($a=0 \dots z=25$).

Encryption: $C = (P \times K) \bmod 26$ **Decryption:** $P = (C \times K^{-1}) \bmod 26$

- P = row of plaintext numbers (block size = size of key matrix), K = key matrix.
- The key matrix must be **invertible mod 26**: $\gcd(\text{determinant}, 26) = 1$.
- If the last block is short, pad with a filler letter (x or z).

Solved (W2025): plaintext "decisions", key $K = [[5, 7, 10], [3, 1, 7], [0, 5, 2]]$

Numbers: d=3, e=4, c=2, i=8, s=18, i=8, o=14, n=13, s=18. Blocks of 3: (d e c), (i s i), (o n s).

Check key: $\det(K) = 5(2-35) - 7(6-0) + 10(15-0) = -165 - 42 + 150 = -57 \equiv 21 \pmod{26}$.
 $\gcd(21, 26) = 1 \rightarrow$ invertible ✓

Block	Row $\times$ K (each column)	Mod 26	Letters
(3, 4, 2)	$3 \times 5 + 4 \times 3 + 2 \times 0 = 27$ $3 \times 7 + 4 \times 1 + 2 \times 5 = 35$ $3 \times 10 + 4 \times 7 + 2 \times 2 = 62$	1, 9, 10	BJK
(8, 18, 8)	$8 \times 5 + 18 \times 3 + 8 \times 0 = 94$ $8 \times 7 + 18 \times 1 + 8 \times 5 = 114$ $8 \times 10 + 18 \times 7 + 8 \times 2 = 222$	16, 10, 14	QKO
(14, 13, 18)	$14 \times 5 + 13 \times 3 + 18 \times 0 = 109$ $14 \times 7 + 13 \times 1 + 18 \times 5 = 201$ $14 \times 10 + 13 \times 7 + 18 \times 2 = 267$	5, 19, 7	FTH

Ciphertext = BJKQKOFTH

Q3(a) OR [3 marks] Explain keyed transposition cipher with example.

★ Repeated topic - also asked in Summer 2026: Q3(c) (7M)

Keyed transposition cipher: plaintext is divided into **blocks** (size = key length) and the letters of each block are **permuted** according to a secret key (a permutation).

Example: key = (3 1 4 2) means plaintext letter in position 1 moves to position 3, position 2 $\rightarrow$ 1, position 3 $\rightarrow$ 4, position 4 $\rightarrow$ 2.

Plain block	H E L P
Key (position moves to)	1→3, 2→1, 3→4, 4→2
Cipher block	E P H L

Ciphertext = EPHL. Longer messages are split into blocks of 4 (pad the last block with a dummy letter, e.g. X) and each block is permuted the same way.

Decryption uses the inverse key: swap the roles of positions and values. Inverse of (3 1 4 2) is (2 4 1 3). Applying it to EPHL gives back HELP ✓.

Q3(b) OR [4 marks] Encrypt "battery" using Playfair cipher. Key: FORUM.

Playfair cipher: encrypts **pairs of letters (digraphs)** using a 5 × 5 key square (I and J share one cell).

Steps

1. Build the 5 × 5 grid: write the key (no repeated letters) first, then the remaining alphabet letters.
2. Split plaintext into pairs. If a pair has the **same letters**, insert **X** between them. If one letter is left alone, add **X**.
3. **Same row** → take the letter to the **right** of each (wrap around).
4. **Same column** → take the letter **below** each (wrap around).
5. **Rectangle** → each letter is replaced by the letter in **its own row** and the **other letter's column**.

Solved: plaintext BATTERY, key FORUM

Grid (key FORUM in first row, then A B C D E G H I K L N P Q S T V W X Y Z):

F	O	R	U	M
A	B	C	D	E
G	H	I	K	L
N	P	Q	S	T
V	W	X	Y	Z

Pairs: BA | TT → TX | TE | RY → **BA, TX, TE, RY**

Pair	Rule	Result
BA	Same row (2nd row): B → C, A → B	CB
TX	Rectangle: T (row 4, col 5), X (row 5, col 3) → Q, Z	QZ
TE	Same column (col 5): T → Z (below), E → L (below)	ZL
RY	Rectangle: R (row 1, col 3), Y (row 5, col 4) → U, X	UX

Ciphertext = CBQZZLUX

Q3(c) OR [7 marks] Explain key-generation of RSA with example. Show encryption and decryption using RSA with example.

★ Repeated topic - also asked in Summer 2026: Q3(c) OR (7M)

RSA (Rivest-Shamir-Adleman) is the most popular public-key algorithm. Its security depends on the difficulty of **factoring a large number n into its primes p and q**.

Key generation

1. Choose two large primes **p** and **q**.
2. Calculate **n = p × q**.
3. Calculate **φ(n) = (p - 1)(q - 1)**.

4. Choose **e** with $1 < e < \phi(n)$ and $\gcd(e, \phi(n)) = 1$.
5. Find **d** such that $(d \times e) \bmod \phi(n) = 1$ (use Extended Euclid).
6. **Public key** = {**e**, **n**}, **Private key** = {**d**, **n**}.

Encryption: $C = M^e \bmod n$ **Decryption:** $M = C^d \bmod n$ (M must be less than n).

Solved example: $p = 5, q = 11, e = 7, M = 4$

Step	Calculation
n	$5 \times 11 = 55$
$\phi(n)$	$(5 - 1)(11 - 1) = 4 \times 10 = 40$
e	7 ($\gcd(7, 40) = 1 \checkmark$)
d	$7 \times d \equiv 1 \pmod{40} \rightarrow d = 23$, because $7 \times 23 = 161 = 4 \times 40 + 1$
Keys	Public = {7, 55}; Private = {23, 55}
Encryption	$C = 4^7 \bmod 55$. $4^2 = 16$; $4^4 = 256 \bmod 55 = 36$; $4^7 = 4^4 \times 4^2 \times 4 = 36 \times 16 \times 4 \rightarrow (576 \bmod 55 = 26) \rightarrow 26 \times 4 = 104 \bmod 55 = \mathbf{49}$
Decryption	$M = 49^{23} \bmod 55$. $49^2 \bmod 55 = 36$; $49^4 = 36^2 = 1296 \bmod 55 = 31$; $49^8 = 31^2 = 961 \bmod 55 = 26$; $49^{16} = 26^2 = 676 \bmod 55 = 16$. Since $23 = 16 + 4 + 2 + 1$: $16 \times 31 \times 36 \times 49 \bmod 55 = (496 \bmod 55 = 1) \rightarrow 1 \times 36 = 36 \rightarrow 36 \times 49 = 1764 \bmod 55 = \mathbf{4}$

Decrypted message = 4 = original $M \checkmark$.

Exam tip: In exams just show the steps (n, ϕ, d, C, M). If your calculator cannot do large powers, use the square-and-multiply method shown above.

Q4(a) [3 marks] Discuss the web security threats on integrity and confidentiality.

★ Repeated topic - also asked in Summer 2026: Q4(a) (3M)

The web is a two-way network, so servers and browsers both face attacks. Threats are grouped by what they damage:

Threat type	Examples of threats	Consequence	Countermeasure
Integrity	Modification of user data; Trojan-horse browser; modification of memory; modification of messages in transit	Loss of data, machine compromise, vulnerability to other threats	Cryptographic checksums (hash, MAC)
Confidentiality	Eavesdropping on the network; theft of info from server or client; info about network configuration; traffic analysis	Loss of information, loss of privacy	Encryption, web proxies
Denial of Service	Killing user threads; flooding with bogus requests; filling disk/memory; isolating machine by DNS attacks	Disruption, prevents users from getting work done	Difficult to prevent fully
Authentication	Impersonation of legitimate users; data forgery	Misrepresentation of user, belief that false info is valid	Cryptographic techniques (certificates)

Exam tip: 3 marks 'three threats': write Integrity, Confidentiality and Denial of Service with one example line each. For the W2025 wording (integrity + confidentiality) use the first two rows in more detail.

Q4(b) [4 marks] Draw and discuss SSL protocol stack in short.

★ Repeated topic - also asked in Summer 2026: Q4(b) (4M)

Handshake Protocol	Change Cipher Spec	Alert Protocol	HTTP
SSL Record Protocol			
TCP			
IP			

SSL (Secure Socket Layer) was developed by Netscape. It provides **confidentiality** and **message integrity** for TCP-based applications. SSL is a **two-layer** protocol:

- **SSL Record Protocol** (lower layer): provides basic security. Steps: *fragment* → *compress* → *add MAC* → *encrypt* → *add header*. Gives confidentiality (symmetric encryption) and integrity (MAC).
- **Handshake Protocol**: the most complex part. Client and server authenticate each other, negotiate the encryption algorithm, MAC algorithm and cryptographic keys. It runs in 4 phases: (1) hello messages, (2) server certificate and key exchange, (3) client certificate and key exchange, (4) change cipher suite and finish.
- **Change Cipher Spec Protocol**: a single message (value 1) that tells the other side to start using the newly agreed cipher keys.
- **Alert Protocol**: sends alert messages to the peer; each has a level (**warning** or **fatal**) and a code. Fatal alerts end the connection immediately.

Session vs connection: a *connection* is a temporary peer-to-peer link; a *session* is an association created by the Handshake protocol that can cover many connections (avoids repeating the expensive handshake).

Q4(c) [7 marks] For secure electronic transaction, explain role of its participants. Enlist sequence of events during transaction.

★ Repeated topic - also asked in Summer 2026: Q4(c) OR (7M)

SET (Secure Electronic Transaction) is an open protocol developed by **Visa and MasterCard (1996)** to protect **credit-card payments over the internet**. It uses digital certificates (X.509) and a **dual signature**.

Services provided

- Confidentiality of payment and order information.
- Integrity of all transmitted data.
- Authentication of cardholder and merchant (using certificates).
- Privacy: merchant sees only the order, bank sees only the payment.

Participants and their role

Participant	Role
Cardholder	Authorised holder of a payment card (customer). Places the order and pays.
Merchant	Seller of goods/services; offers them for sale and accepts card payments (has certificates).
Issuer	Financial institution (bank) that issued the card to the cardholder; guarantees payment if the transaction is valid.
Acquirer	Merchant's bank; processes card authorisations and payments; gets money from the issuer.
Payment gateway	Operated by the acquirer; links SET to the banking network; processes merchant's authorisation and payment messages.
Certification Authority (CA)	Trusted authority that issues X.509v3 certificates to cardholders, merchants and gateways.

Sequence of events in a transaction

1. Customer **opens an account** with a card-issuing bank (e.g. a credit card).
2. Customer **receives a certificate** (digitally signed by the bank).
3. **Merchants have their own certificates** (one for signing and one for key exchange).
4. Customer **places an order**.
5. Merchant sends its certificate so the customer can **verify the merchant is valid**.
6. Customer sends **order and payment information**, with a **dual signature**: order info is readable only by the merchant, payment info only by the bank.
7. Merchant **requests payment authorisation** from the payment gateway.
8. Merchant **confirms the order** to the customer.
9. Merchant **ships the goods** or provides the service.
10. Merchant **requests payment** from the payment gateway.

Q4(a) OR [3 marks] To provide web security, discuss the approaches at network, transport and application level.

★ Repeated topic - also asked in Summer 2026: Q5(a) (3M)

Web traffic security can be added at **three levels** of the protocol stack:

Level	Protocol	How it works	Pros / cons
Network level	IPsec	Security added at the IP layer; encrypts/authenticates all IP packets	Transparent to all applications; but needs OS/router support
Transport level	SSL / TLS	Sits between TCP and the application; secures any TCP-based application (HTTP, FTP, SMTP)	Most common for web (HTTPS); built into browsers
Application level	SET, S/MIME, PGP, Kerberos	Security built into the particular application	Can be tailored to the application's needs, but each application needs its own

Exam tip: 3 marks: name the three levels with the protocol for each (IPsec, SSL/TLS, SET/S/MIME/PGP) and one line each.

Q4(b) OR [4 marks] Give the full form of TLS and HTTPS. Explain HTTPS connection initiation.

★ Repeated topic - also asked in Summer 2026: Q4(c) (7M)

How much to write: Write the full forms and the 'Connection initiation' part only (skip closure).

Full forms: **TLS** = Transport Layer Security; **HTTPS** = HyperText Transfer Protocol Secure (HTTP over SSL/TLS). HTTPS uses **port 443** and the URL starts with **https://**.

Connection initiation

In HTTPS the HTTP client also acts as the **TLS client**:



1. Client (browser) opens a TCP connection to the server on port 443.
2. TLS handshake begins: client sends **ClientHello** (supported ciphers); server replies with **ServerHello** and its **certificate**.
3. Client verifies the certificate, both sides exchange keys and agree on session keys, then send **Finished**.

4. Only after the TLS connection is established does the client send the **HTTP request**. The request and the reply travel inside TLS records, so URL, headers, cookies, form data and page content are all **encrypted**.

Q4(c) OR [7 marks] Compare SSL (Secure Socket Layer) with SET (Secure Electronic Transaction).

★ Repeated topic - also asked in Summer 2026: Q5(a) OR (3M)

Point	SSL	SET
Purpose	General-purpose security for any TCP application	Specially for credit-card payments on the web
Layer	Transport layer (between TCP and application)	Application layer
Authentication	Server is authenticated; client authentication is optional	All parties (cardholder, merchant, gateway) are authenticated with certificates
Card details	Merchant can see the card number	Merchant never sees the card number (dual signature)
Non-repudiation	Not provided	Provided (digital signatures)
Complexity / cost	Simple, built into browsers, easy to use	Complex, needs special software/wallet and certificates for all
Use today	Very widely used (HTTPS)	Rarely used now

Exam tip: For a 3-mark answer write only the first three rows (purpose, layer, authentication). For 7 marks write all rows.

Q5(a) [3 marks] If the key is 11 and its multiplicative inverse key = 19, decrypt the cipher-text "dagcq" encrypted using multiplicative cipher.

Multiplicative cipher: key K is multiplied with plaintext number. K must be **co-prime with 26** (so an inverse exists).

Encryption: $C = (P \times K) \bmod 26$ **Decryption:** $P = (C \times K^{-1}) \bmod 26$

Valid keys: **1, 3, 5, 7, 9, 11, 15, 17, 19, 21, 23, 25** (12 keys). Inverse pairs: 3↔9, 5↔21, 7↔15, 11↔19, 17↔23; 1, 25 are their own inverses.

Solved (W2025): decrypt "dagcq", key = 11, inverse = 19

Decryption: $P = (C \times 19) \bmod 26$. (Check: $11 \times 19 = 209 = 8 \times 26 + 1 \checkmark$)

Cipher letter	D	A	G	C	Q	O
C (number)	3	0	6	2	16	14
$C \times 19$	57	0	114	38	304	266
$(C \times 19) \bmod 26$	5	0	10	12	18	6
Plain letter	f	a	k	m	s	g

Plaintext = fakmsg

Verification: encrypt $f = 5 \rightarrow 5 \times 11 = 55 \bmod 26 = 3 = d \checkmark$.

Q5(b) [4 marks] Explain the need of firewall in the network security.

★ Repeated topic - also asked in Summer 2026: Q5(c) OR (7M)

A **firewall** is a security system (hardware, software or both) placed between a **trusted internal network** and an **untrusted network (internet)** that **filters traffic** according to a security

policy.



Need of firewall

1. **Blocks unauthorised access** and hackers from outside into the private network.
2. **Single control point** - all traffic passes through one place, so security policy is easy to apply and monitor.
3. **Filters traffic** by IP address, port, protocol or content; blocks malicious packets and some malware/DoS attempts.
4. **Hides internal network** (e.g. NAT) so outsiders cannot see internal IP addresses.
5. **Logging and auditing** of network activity helps to trace attacks.
6. Controls what internal users can reach (e.g. block certain websites).

Q5(c) [7 marks] Define intrusion, intrusion detection and intrusion detection system. Explain misuse detection and anomaly detection approaches.

★ Repeated topic - also asked in Summer 2026: Q5(b) (4M), Q5(b) OR (4M)

- **Intrusion:** any unauthorised or malicious activity that tries to break the confidentiality, integrity or availability of a system or network.
- **Intrusion detection:** the process of **monitoring** events in a system or network and **analysing** them for signs of intrusion.
- **Intrusion Detection System (IDS):** hardware or software that does intrusion detection automatically and **raises an alarm** to the administrator.

Approaches to intrusion detection

1) Misuse detection (signature-based): the system keeps a database of **known attack patterns (signatures / rules)**. Events are compared with it; a match = alarm. *Like an antivirus.*

2) Anomaly detection (behaviour-based): the system first learns a **normal behaviour profile** of users/system (login time, files used, traffic volume). Any **significant deviation** is treated as a possible intrusion. Uses statistical methods or rule-based methods.

Point	Misuse detection	Anomaly detection
Based on	Known attack signatures	Normal behaviour profile
New (unknown) attacks	Cannot detect	Can detect
False alarms	Few	Many (false positives)
Maintenance	Signature database must be updated regularly	Profile must be retrained as behaviour changes

Q5(a) OR [3 marks] Explain the categories of the intruders in the system security.

An **intruder** is a person or program that tries to gain unauthorised access to a system. Three classes (Anderson):

Class	Who is it?	Example
Masquerader	An outsider not authorised to use the computer, who penetrates access controls and uses a legitimate user's account	Using a stolen password to log in
Misfeasor	A legitimate user (insider) who accesses data, programs or resources he is not authorised for, or misuses his privileges	Employee reading salary files of others
Clandestine user	Someone (insider or outsider) who seizes supervisory control of the system and uses it to avoid auditing and access controls or to suppress audit collection	Admin-level hacker deleting log files

Q5(b) OR [4 marks] Explain the working of one-time pad algorithm with example.

One-time pad (Vernam cipher): the key is a **truly random** string, **as long as the message**, and used **only once**. It gives **perfect secrecy** (unbreakable) because any plaintext of that length is equally possible.

Encryption: $C = (P + K) \bmod 26$ **Decryption:** $P = (C - K) \bmod 26$ (for binary data: $C = P \oplus K$).

Example: plaintext HELLO, random key XMCKL

Plain letter	H	E	L	L	O
P	7	4	11	11	14
Key letter	X	M	C	K	L
K	23	12	2	10	11
(P + K) mod 26	4	16	13	21	25
Cipher letter	E	Q	N	V	Z

Ciphertext = EQNVZ. Decryption: $E(4) - X(23) = -19 \equiv 7 = H$, and so on.

- **Advantages:** perfect secrecy, simple.
- **Problems:** key must be as long as message, truly random, never reused, and hard to distribute safely - so it is used only in very high-security cases.

Q5(c) OR [7 marks] Explain packet filtering firewall, application and circuit-level gateway.

★ Repeated topic - also asked in Summer 2026: Q5(c) (7M)

1) Packet-filtering firewall (network layer)

Checks **each packet separately** against a set of rules (ACL) using header information: **source/destination IP address, port numbers, protocol (TCP/UDP/ICMP)**. Packet is **allowed or dropped** according to the first matching rule. It does not look at the data inside.

- **Advantages:** fast, cheap, transparent to users.
- **Disadvantages:** does not inspect payload; weak against IP spoofing; rules are hard to write; no user authentication; limited logging.

2) Application-level gateway / proxy firewall (application layer)

Works as a **proxy**. The user connects to the gateway, the gateway checks the request (user ID, command, content) and then makes a **separate connection to the real server** on the user's behalf. A separate proxy is needed for each application (HTTP, FTP, Telnet).

- **Advantages:** most secure; inspects application data; good logging; hides internal network.
- **Disadvantages:** slower (extra processing and two connections); one proxy per application.

3) Circuit-level gateway (transport layer)

Does **not inspect the data**. It sets up **two TCP connections**: one between itself and the inside user, and another between itself and the outside host. Once the connection is allowed (after checking handshake), it simply **relays the TCP segments** from one connection to the other. Example: SOCKS.

- **Advantages:** faster than application gateway; hides internal network.
- **Disadvantages:** no content filtering - once a circuit is allowed, anything can pass.

Point	Packet filter	Application gateway	Circuit-level gateway
OSI layer	Network	Application	Transport (session)
Checks	IP, port, protocol of each packet	Full application data and user	TCP connection set-up
Speed	Fastest	Slowest	Medium
Security	Lowest	Highest	Medium

Solved paper - Summer 2026 (14-05-2026)

Q1(a) [3 marks] Define cryptography and cryptanalysis.

How much to write: For 3 marks write only the two definitions (skip the classification).

- **Cryptography:** the science and art of keeping information secret by converting **plaintext** (readable) into **ciphertext** (unreadable) using algorithms and keys, and converting it back. Example: HELLO → KHOOR (shift by 3).
- **Cryptanalysis:** the science of **breaking** ciphers, i.e. finding the plaintext or the key from ciphertext **without** knowing the key. Example: trying all keys (brute force) or using letter-frequency analysis.
- **Cryptology** = Cryptography + Cryptanalysis.

Classification of cryptographic algorithms (syllabus 1.8)

Cryptography

Keyless
(no key)

Single-key
(symmetric)

Two-key
(asymmetric)

Type	Key used	Examples
Keyless	No key at all	Hash functions (SHA, MD5), pseudo-random generators
Single-key (symmetric)	Same secret key for encryption and decryption	Caesar, Vigenère, DES, AES
Two-key (asymmetric)	Public key encrypts, private key decrypts (or vice versa)	RSA, ECC, Diffie-Hellman

Q1(b) [4 marks] Differentiate between substitution and transposition technique with example.

Point	Substitution technique	Transposition technique
Meaning	Each letter is replaced by another letter / number / symbol	Positions of letters are rearranged ; letters stay the same
Identity of letters	Changed	Not changed (only order changes)
Types	Additive, multiplicative, affine, monoalphabetic, Vigenère, Playfair, Hill, one-time pad	Rail fence, rectangular (columnar), keyed transposition, keyed columnar
Example	HELLO → KHOOR (Caesar, shift 3)	HELLO → HLOEL (rail fence, 2 rails)
Weakness	Letter-frequency analysis	Anagramming; letter frequency stays same as plaintext

Modern ciphers (DES, AES) combine **both** techniques repeatedly.

Q1(c) [7 marks] Classify Security Attacks and explain any three in brief (active attacks).

★ Repeated topic - also asked in Winter 2025: Q2(c) OR (7M)

How much to write: Draw the classification diagram, then explain any three active attacks.

Security Attacks

PASSIVE attacks
Release of message contents
Traffic analysis

ACTIVE attacks
Masquerade | Replay
Modification | Denial of Service

A) Passive attacks - attacker only watches, does not change anything

- **Release of message contents:** attacker reads (eavesdrops) an email, phone call or file.
Example: sniffing an unencrypted Wi-Fi password.
- **Traffic analysis:** even if the message is encrypted, attacker studies the pattern - who talks to whom, how often, message length - and guesses useful information.

Passive attacks are **very hard to detect** (nothing changes) but **can be prevented** by encryption.

B) Active attacks - attacker changes data or disturbs the system

- **Masquerade:** one entity pretends to be another. *Example: using a stolen password to log in as someone else.*
- **Replay:** attacker captures a valid message and sends it again later to get an unauthorised effect. *Example: re-sending a captured 'transfer Rs.5,000' request.*
- **Modification of messages:** part of a genuine message is altered, delayed or reordered.
Example: 'Pay Rs.100 to A' changed to 'Pay Rs.900 to B'.
- **Denial of Service (DoS):** attacker floods a server or network so genuine users cannot use it.
Example: millions of fake requests crash a website.

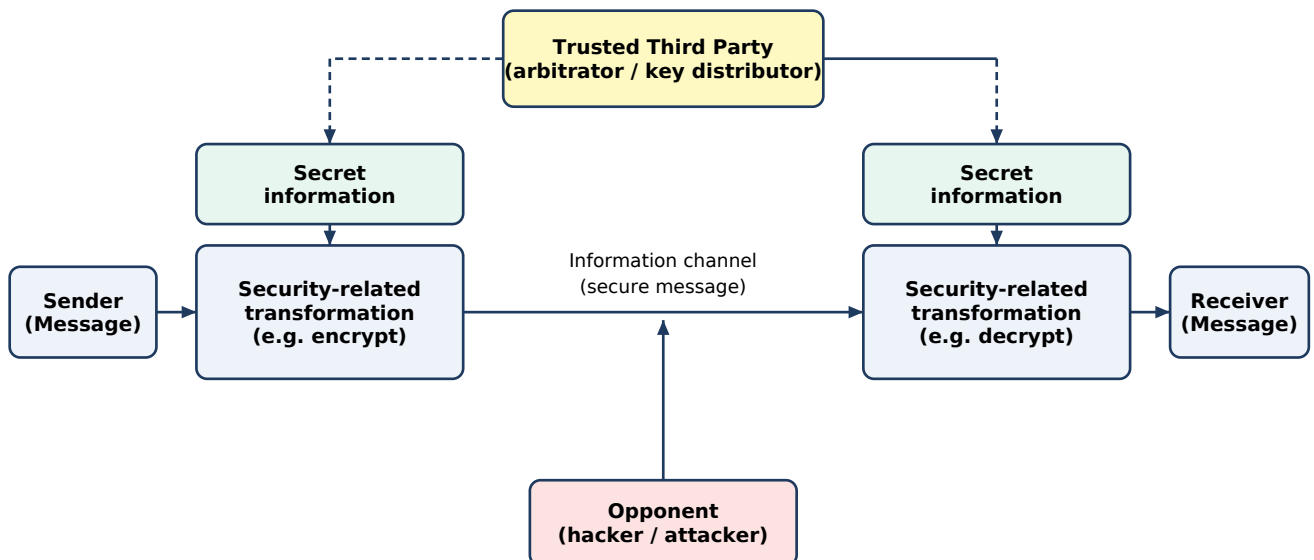
Active attacks are **easy to detect** but **hard to prevent completely** - so we try to detect and recover.

Point	Passive attack	Active attack
Data	Not altered	Altered or created
Goal	Learn information	Damage / change / disturb
Detection	Very difficult	Easier
Prevention	Possible (encryption)	Difficult (detect + recover)
Threatens	Confidentiality	Integrity, Availability, Authenticity

Exam tip: For '7 marks' draw the classification diagram, write 2 passive + 4 active with one example each, and add the comparison table.

Q1(c) OR [7 marks] Draw and explain the model for network security.

★ Repeated topic - also asked in Winter 2025: Q2(b) (4M)



Explanation: A message must travel from the **sender** to the **receiver** over an **information channel** (internet). An **opponent** may attack this channel. So a **security-related transformation** is applied:

- At the sender: the message is transformed (e.g. **encrypted**) using **secret information** (a key), so it becomes unreadable for the opponent.
- At the receiver: the reverse transformation (e.g. **decryption**) is done using the secret information to get the original message.
- A **trusted third party** may be needed to distribute the secret information (keys) or to settle disputes between sender and receiver.

Four tasks while designing a security service (for 7 marks)

1. Design an **algorithm** for the security transformation that is hard for an opponent to break.
2. **Generate the secret information** (keys) to be used with the algorithm.
3. Develop methods for **distribution and sharing** of the secret information.
4. Specify a **protocol** that uses the algorithm and secret information to provide the security service.

Exam tip: 4 marks: diagram + 3-4 lines. 7 marks: diagram + explanation + the four design tasks.

Q2(a) [3 marks] Define confidentiality, integrity, and availability.

★ Repeated topic - also asked in Winter 2025: Q1(a) (3M)

CIA triad = the three main goals of computer security.

Goal	Meaning (simple)	Example	How we get it
Confidentiality	Only authorised people can read the information. Keep it secret.	ATM PIN, encrypted chat	Encryption, passwords
Integrity	Information is not changed by unauthorised people. Keep it the same.	Hacker changes Rs.1,000 to Rs.10,000 in a bank record = integrity lost	Hash, digital signature, checksum
Availability	Data and services are available whenever authorised users need them. Keep it running.	Website crashing due to a DoS attack = availability lost	Backup, redundancy, firewall

Two extra requirements (for 4-7 marks):

- **Authenticity** - the message/user is genuine and can be verified (it really came from who it says).

- **Accountability** - every action can be traced to the person who did it (logs), so nobody can deny it later.

Easy way to remember: Confidentiality = **Secret**, Integrity = **Same (unchanged)**, Availability = **Always on**.

Q2(b) [4 marks] Explain modular arithmetic properties over addition, subtraction and multiplication with example.

★ Repeated topic - also asked in Winter 2025: Q2(a) OR (3M)

Modulo operator: $a \bmod n$ gives the **remainder** when a is divided by n . Example: $17 \bmod 5 = 2$. If $a \bmod n = b \bmod n$ we write $a \equiv b \pmod{n}$.

Three properties (use any numbers - here $a = 12$, $b = 11$, $n = 7$)

Property	Left side	Right side	Result
Addition: $(a + b) \bmod n = [(a \bmod n) + (b \bmod n)] \bmod n$	$23 \bmod 7 = 2$	$(5 + 4) \bmod 7 = 9 \bmod 7 = 2$	Equal ✓
Subtraction: $(a - b) \bmod n = [(a \bmod n) - (b \bmod n)] \bmod n$	$1 \bmod 7 = 1$	$(5 - 4) \bmod 7 = 1$	Equal ✓
Multiplication: $(a \times b) \bmod n = [(a \bmod n) \times (b \bmod n)] \bmod n$	$132 \bmod 7 = 6$	$(5 \times 4) \bmod 7 = 20 \bmod 7 = 6$	Equal ✓

Prove: $a = 12$, $b = 11$, $n = 7 \rightarrow (a \times b) \bmod n = [(a \bmod n) \times (b \bmod n)] \bmod n$

LHS: $(12 \times 11) \bmod 7 = 132 \bmod 7$. Since $132 = 18 \times 7 + 6$, LHS = **6**.

RHS: $12 \bmod 7 = 5$ and $11 \bmod 7 = 4$. So $[(5) \times (4)] \bmod 7 = 20 \bmod 7 = \mathbf{6}$ (because $20 = 2 \times 7 + 6$).

LHS = RHS = 6. **Hence proved.**

General reason: write $a = n \cdot q_1 + r_1$ and $b = n \cdot q_2 + r_2$. Then $a \times b = n(\dots) + r_1 \times r_2$, so $a \times b$ leaves the same remainder as $r_1 \times r_2$.

Q2(c) [7 marks] Calculate multiplicative inverse of 23 in Z_{100} using Extended Euclidean Algorithm.

★ Repeated topic - also asked in Winter 2025: Q1(c) OR (7M)

Extended Euclidean algorithm finds the GCD and the **multiplicative inverse** of b in Z_n . (The paper's s-columns are the 't' columns of the book.)

Algorithm (to find inverse of b in Z_n)

1. Set $r_1 = n$, $r_2 = b$, $s_1 = 0$, $s_2 = 1$.
 2. While $r_2 > 0$: $q = r_1 \div r_2$; $r = r_1 - q \times r_2$; $s = s_1 - q \times s_2$; then shift: $r_1 = r_2$, $r_2 = r$, $s_1 = s_2$, $s_2 = s$.
 3. When $r_2 = 0$: if $r_1 = 1$ the inverse exists and **inverse = $s_1 \bmod n$** . If $r_1 \neq 1$, no inverse exists.
- ```

r1, r2 = n, b ; s1, s2 = 0, 1
while r2 > 0:
 q = r1 // r2
 r, s = r1 - q*r2, s1 - q*s2
 r1, r2, s1, s2 = r2, r, s2, s
if r1 == 1: inverse = s1 % n

```

**Solved: multiplicative inverse of 23 in  $Z_{100}$  ( $n = 100$ ,  $b = 23$ )**

| q | r1  | r2 | r | s1 | s2  | s   |
|---|-----|----|---|----|-----|-----|
| 4 | 100 | 23 | 8 | 0  | 1   | -4  |
| 2 | 23  | 8  | 7 | 1  | -4  | 9   |
| 1 | 8   | 7  | 1 | -4 | 9   | -13 |
| 7 | 7   | 1  | 0 | 9  | -13 | 100 |

$r1 = 1 = 1$ , so the inverse exists.  $s1 = -13$ , so inverse =  $-13 \bmod 100 = 87$ .

**Check:**  $23 \times 87 = 2001 = 20 \times 100 + 1 \rightarrow 2001 \bmod 100 = 1 \checkmark$

## Q2(a) OR [3 marks] State any three security mechanisms.

A **security mechanism** is a method/tool used to detect, prevent or recover from an attack. There are two groups:

### Specific security mechanisms (used in a particular protocol layer / service)

- **Encipherment:** converting data into unreadable form using algorithms and keys.
- **Digital signature:** data added to a message that proves who sent it and that it was not changed.
- **Access control:** methods that enforce who can use which resource.
- **Data integrity:** checks (hash/checksum) that data was not altered.
- **Authentication exchange:** two parties exchange information to prove their identity.
- **Traffic padding:** inserting fake bits so traffic analysis is difficult.
- **Routing control:** choosing physically secure routes for sensitive data.
- **Notarization:** a trusted third party guarantees properties of the data exchange.

### Pervasive security mechanisms (not tied to one service or layer)

- **Trusted functionality:** a function that is considered correct and trusted.
- **Security label:** marking of a resource (e.g. 'Confidential', 'Secret').
- **Event detection:** detecting security-related events.
- **Security audit trail:** records of events kept for later review.
- **Security recovery:** actions taken to recover after an attack.

**Exam tip:** For a 3-mark 'any three' question just write three specific mechanisms with one line each, as above.

## Q2(b) OR [4 marks] Explain the concept of residue set $Z_n$ with example.

★ Repeated topic - also asked in Winter 2025: Q2(b) OR (4M)

- **$Z_n$  (set of residues):** all possible remainders when dividing by  $n$ .  $Z_n = \{0, 1, 2, \dots, n-1\}$ .  
 $Z_7 = \{0, 1, 2, 3, 4, 5, 6\}$ .
- **$Z_n^*$  (set of multiplicative inverses):** only those members of  $Z_n$  which have a multiplicative inverse, i.e. numbers with  $\gcd(a, n) = 1$  (co-prime to  $n$ ). Zero is never in  $Z_n^*$ .
- **$Z_7^* = \{1, 2, 3, 4, 5, 6\}$**  (7 is prime, so every non-zero number is co-prime to 7).
- Another example:  **$Z_{10}^* = \{1, 3, 7, 9\}$**  (2, 4, 5, 6, 8 share a factor with 10).

### Inverses

- **Additive inverse** of  $a$ : the number  $b$  such that  $a + b \equiv 0 \pmod{n}$ . Every member of  $Z_n$  has one.
- **Multiplicative inverse** of  $a$ : the number  $b$  such that  $a \times b \equiv 1 \pmod{n}$ . Exists only if  $\gcd(a, n) = 1$ .

| Z7 member              | 0 | 1 | 2 | 3 | 4 | 5 | 6 |
|------------------------|---|---|---|---|---|---|---|
| Additive inverse       | 0 | 6 | 5 | 4 | 3 | 2 | 1 |
| Multiplicative inverse | - | 1 | 4 | 5 | 2 | 3 | 6 |

Check:  $3 \times 5 = 15 = 2 \times 7 + 1 \rightarrow 3$  and 5 are multiplicative inverses in  $Z_7$ .  $Z_7$  and  $Z_7^*$  differ only by the number 0.

### Addition and multiplication tables of $Z_5$ (syllabus 2.3.3)

Addition table of  $Z_5$

| + | 0 | 1 | 2 | 3 | 4 |
|---|---|---|---|---|---|
| 0 | 0 | 1 | 2 | 3 | 4 |
| 1 | 1 | 2 | 3 | 4 | 0 |
| 2 | 2 | 3 | 4 | 0 | 1 |
| 3 | 3 | 4 | 0 | 1 | 2 |
| 4 | 4 | 0 | 1 | 2 | 3 |

Multiplication table of  $Z_5$

| $\times$ | 0 | 1 | 2 | 3 | 4 |
|----------|---|---|---|---|---|
| 0        | 0 | 0 | 0 | 0 | 0 |
| 1        | 0 | 1 | 2 | 3 | 4 |
| 2        | 0 | 2 | 4 | 1 | 3 |
| 3        | 0 | 3 | 1 | 4 | 2 |
| 4        | 0 | 4 | 3 | 2 | 1 |

In the addition table, 0 appears in every row/column (so every number has an additive inverse). In the multiplication table, 1 appears in every non-zero row (so every non-zero number has a multiplicative inverse).

### Q2(c) OR [7 marks] Find GCD(2740, 1760) using Euclidean Algorithm.

★ Repeated topic - also asked in Winter 2025: Q1(c) (7M)

**Euclidean algorithm** finds the **GCD** (greatest common divisor) of two numbers. Idea:  $\gcd(a, b) = \gcd(b, a \bmod b)$ ; keep going until the remainder is 0.

#### Algorithm

1. Take  $a > b$ . Set  **$r_1 = a$ ,  $r_2 = b$** .
2. While  $r_2 > 0$ :  **$q = r_1 \div r_2$**  (integer division);  **$r = r_1 - q \times r_2$** ; then set  $r_1 = r_2$  and  $r_2 = r$ .
3. When  $r_2$  becomes 0,  **$\gcd(a, b) = r_1$** .

```

r1 = a; r2 = b
while r2 > 0:
 q = r1 // r2
 r = r1 - q * r2
 r1 = r2
 r2 = r
gcd = r1

```

**Solved: GCD(2740, 1760)**

| q | r1   | r2   | r   |
|---|------|------|-----|
| 1 | 2740 | 1760 | 980 |
| 1 | 1760 | 980  | 780 |
| 1 | 980  | 780  | 200 |
| 3 | 780  | 200  | 180 |
| 1 | 200  | 180  | 20  |
| 9 | 180  | 20   | 0   |

When  $r_2 = 0$ ,  $r_1 = 20$ . **GCD(2740, 1760) = 20.**

**Q3(a) [3 marks] Apply Vigenère cipher to encrypt "KEEP MESSAGE SECRET" using key = CIPHER.**

**Vigenère cipher:** polyalphabetic. A keyword is **repeated** under the plaintext; each letter is shifted by the key letter (A=0 ... Z=25).

**Encryption:**  $C_i = (P_i + K_i) \bmod 26$     **Decryption:**  $P_i = (C_i - K_i) \bmod 26$

**Solved (S2026): "KEEP MESSAGE SECRET", key = CIPHER**

Remove spaces → KEPPMESSAGESECRET (17 letters). Repeat key CIPHERCIPHERCIPHE...

|              |    |    |    |    |    |    |    |    |    |    |   |    |   |    |    |    |    |
|--------------|----|----|----|----|----|----|----|----|----|----|---|----|---|----|----|----|----|
| Plain        | K  | E  | E  | P  | M  | E  | S  | S  | A  | G  | E | S  | E | C  | R  | E  | T  |
| P            | 10 | 4  | 4  | 15 | 12 | 4  | 18 | 18 | 0  | 6  | 4 | 18 | 4 | 2  | 17 | 4  | 19 |
| Key          | C  | I  | P  | H  | E  | R  | C  | I  | P  | H  | E | R  | C | I  | P  | H  | E  |
| K            | 2  | 8  | 15 | 7  | 4  | 17 | 2  | 8  | 15 | 7  | 4 | 17 | 2 | 8  | 15 | 7  | 4  |
| (P+K) mod 26 | 12 | 12 | 19 | 22 | 16 | 21 | 20 | 0  | 15 | 13 | 8 | 9  | 6 | 10 | 6  | 11 | 23 |
| Cipher       | M  | M  | T  | W  | Q  | V  | U  | A  | P  | N  | I | J  | G | K  | G  | L  | X  |

**Ciphertext = MMTWQVUAPNIJGKGLX**

Note: the Gujarati question says 'KEEP THE MESSAGE SECRET' but the English (authentic) version has no 'THE'.  
If you write the Gujarati version: KEPTHEMESSAGESECRET → MMTWXYGUTZWRIMHLGIGB.

**Q3(b) [4 marks] Perform encryption and decryption of plaintext "HELLO" using Affine cipher (a = 3, b = 7).**

**Affine cipher** = multiplicative + additive cipher together. Two keys (a, b); **a must be co-prime with 26.**

**Encryption:**  $C = (a \times P + b) \bmod 26$     **Decryption:**  $P = a^{-1} \times (C - b) \bmod 26$

**Encryption (a = 3, b = 7)**

|               |    |    |    |    |    |
|---------------|----|----|----|----|----|
| Plain letter  | H  | E  | L  | L  | O  |
| P             | 7  | 4  | 11 | 11 | 14 |
| 3P + 7        | 28 | 19 | 40 | 40 | 49 |
| mod 26 = C    | 2  | 19 | 14 | 14 | 23 |
| Cipher letter | C  | T  | O  | O  | X  |

**Ciphertext = CTOOX**

**Decryption**

Inverse of  $a = 3$  in Z26 is **9** because  $3 \times 9 = 27 = 1 \times 26 + 1$ .

|                      |     |     |    |    |     |
|----------------------|-----|-----|----|----|-----|
| Cipher letter        | C   | T   | O  | O  | X   |
| C                    | 2   | 19  | 14 | 14 | 23  |
| $9 \times (C - 7)$   | -45 | 108 | 63 | 63 | 144 |
| $\text{mod } 26 = P$ | 7   | 4   | 11 | 11 | 14  |
| Plain letter         | H   | E   | L  | L  | O   |

**Plaintext = HELLO ✓**

Number of keys =  $12 \times 26 = 312$ .

**Q3(c) [7 marks] Encrypt "MEETMEAFTERTHEEXAM" using keyed columnar transposition cipher with key 4312.**

★ Repeated topic - also asked in Winter 2025: Q3(a) OR (3M)

**Keyed columnar transposition:** write plaintext **row-wise** in a grid with as many columns as key digits; then read **column-wise in the order given by the key** (column marked 1 first, then 2, ...).

**Solved: plaintext MEETMEAFTERTHEEXAM, key = 4 3 1 2**

Plaintext has 18 letters; with 4 columns we get 5 rows (last row has 2 letters).

| Key → | 4 | 3 | 1 | 2 |
|-------|---|---|---|---|
| Row 1 | M | E | E | T |
| Row 2 | M | E | A | F |
| Row 3 | T | E | R | T |
| Row 4 | H | E | E | X |
| Row 5 | A | M |   |   |

- Column with key 1 (3rd column): **E A R E**
- Column with key 2 (4th column): **T F T X**
- Column with key 3 (2nd column): **E E E E M**
- Column with key 4 (1st column): **M M T H A**

**Ciphertext = EARE TFTX EEEEM MMTHA = EARETFTXEEEEMMMTHA**

**Key inversion (for decryption):** key 4 3 1 2 says column 1 is read 4th, column 2 is read 3rd, column 3 read 1st, column 4 read 2nd. The inverse key is **3 4 2 1**: the 1st block of ciphertext goes to column 3, the 2nd to column 4, the 3rd to column 2, the 4th to column 1. Fill these back and read row by row to get the plaintext.

Assumption: last row is left incomplete (no padding). If your teacher pads with X, say 'assuming padding X' - GTU allows suitable assumptions.

**Q3(a) OR [3 marks] Encrypt the message "SECURITY" using Additive cipher with key = 5.**

★ Repeated topic - also asked in Winter 2025: Q1(b) (4M)

**Additive cipher** (Caesar / shift cipher): letters are numbered **a=0, b=1 ... z=25**. Key K is added to each letter, everything mod 26.

**Encryption:  $C = (P + K) \text{ mod } 26$     Decryption:  $P = (C - K) \text{ mod } 26$**

Key space is only 26 (25 useful keys), so it is easily broken by **brute force** - try all 25 keys. Caesar cipher is the case  $K = 3$ .

**Solved (S2026): plaintext "SECURITY", key = 5**

|                |    |   |   |    |    |    |    |    |
|----------------|----|---|---|----|----|----|----|----|
| Plain letter   | S  | E | C | U  | R  | I  | T  | Y  |
| P (number)     | 18 | 4 | 2 | 20 | 17 | 8  | 19 | 24 |
| (P + 5) mod 26 | 23 | 9 | 7 | 25 | 22 | 13 | 24 | 3  |
| Cipher letter  | X  | J | H | Z  | W  | N  | Y  | D  |

**Ciphertext = XJHZWNYD**

**Q3(b) OR [4 marks] Encrypt the plaintext "DATA" using Hill cipher with key matrix  $\begin{bmatrix} 5 & 8 \\ 17 & 3 \end{bmatrix}$ .**

★ Repeated topic - also asked in Winter 2025: Q3(c) (7M)

**Hill cipher:** polyalphabetic cipher that encrypts a **block of letters** at once using **matrix multiplication** mod 26 ( $a=0 \dots z=25$ ).

**Encryption:  $C = (P \times K) \bmod 26$     Decryption:  $P = (C \times K^{-1}) \bmod 26$**

- P = row of plaintext numbers (block size = size of key matrix), K = key matrix.
- The key matrix must be **invertible mod 26**:  $\gcd(\text{determinant}, 26) = 1$ .
- If the last block is short, pad with a filler letter (x or z).

**Solved (S2026): plaintext "DATA", key  $K = \begin{bmatrix} 5 & 8 \\ 17 & 3 \end{bmatrix}$**

Blocks of 2: (D A) = (3, 0) and (T A) = (19, 0). **Check key:**  $\det = 5 \times 3 - 8 \times 17 = -121 \equiv 9 \pmod{26}$ ;  $\gcd(9, 26) = 1 \checkmark$

| Block   | Row $\times$ K                                                       | Mod 26 | Letters |
|---------|----------------------------------------------------------------------|--------|---------|
| (3, 0)  | $3 \times 5 + 0 \times 17 = 15$<br>$3 \times 8 + 0 \times 3 = 24$    | 15, 24 | PY      |
| (19, 0) | $19 \times 5 + 0 \times 17 = 95$<br>$19 \times 8 + 0 \times 3 = 152$ | 17, 22 | RW      |

**Ciphertext = PYRW**

Note: this uses the row-vector method  $C = P \times K$  (as in Forouzan/Kahate and the W2025 paper). If your teacher uses the column method  $C = K \times P$ , the answer would be PZRL - mention your method clearly in the exam.

**Q3(c) OR [7 marks] Explain RSA algorithm with example ( $p = 5$ ,  $q = 11$ ,  $e = 7$ ,  $M = 4$ ).**

★ Repeated topic - also asked in Winter 2025: Q3(c) OR (7M)

**RSA** (Rivest-Shamir-Adleman) is the most popular public-key algorithm. Its security depends on the difficulty of **factoring a large number  $n$  into its primes  $p$  and  $q$** .

### Key generation

1. Choose two large primes **p** and **q**.
2. Calculate  **$n = p \times q$** .
3. Calculate  **$\phi(n) = (p - 1)(q - 1)$** .
4. Choose **e** with  $1 < e < \phi(n)$  and  **$\gcd(e, \phi(n)) = 1$** .
5. Find **d** such that  **$(d \times e) \bmod \phi(n) = 1$**  (use Extended Euclid).
6. **Public key = {e, n}**, **Private key = {d, n}**.

**Encryption:  $C = M^e \bmod n$     Decryption:  $M = C^d \bmod n$**  (M must be less than n).

**Solved example:  $p = 5$ ,  $q = 11$ ,  $e = 7$ ,  $M = 4$**

| Step       | Calculation                                                                                                                                                                                                                                                                                                                                       |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| n          | $5 \times 11 = 55$                                                                                                                                                                                                                                                                                                                                |
| $\phi(n)$  | $(5 - 1)(11 - 1) = 4 \times 10 = 40$                                                                                                                                                                                                                                                                                                              |
| e          | 7 ( $\text{gcd}(7, 40) = 1 \checkmark$ )                                                                                                                                                                                                                                                                                                          |
| d          | $7 \times d \equiv 1 \pmod{40} \rightarrow d = 23$ , because $7 \times 23 = 161 = 4 \times 40 + 1$                                                                                                                                                                                                                                                |
| Keys       | Public = {7, 55}; Private = {23, 55}                                                                                                                                                                                                                                                                                                              |
| Encryption | $C = 4^7 \bmod 55$ . $4^2 = 16$ ; $4^4 = 256 \bmod 55 = 36$ ; $4^7 = 4^4 \times 4^2 \times 4 = 36 \times 16 \times 4 \rightarrow (576 \bmod 55 = 26) \rightarrow 26 \times 4 = 104 \bmod 55 = \mathbf{49}$                                                                                                                                        |
| Decryption | $M = 49^{23} \bmod 55$ . $49^2 \bmod 55 = 36$ ; $49^4 = 36^2 = 1296 \bmod 55 = 31$ ; $49^8 = 31^2 = 961 \bmod 55 = 26$ ; $49^{16} = 26^2 = 676 \bmod 55 = 16$ . Since $23 = 16 + 4 + 2 + 1$ : $16 \times 31 \times 36 \times 49 \bmod 55 = (496 \bmod 55 = 1) \rightarrow 1 \times 36 = 36 \rightarrow 36 \times 49 = 1764 \bmod 55 = \mathbf{4}$ |

Decrypted message = 4 = original M  $\checkmark$ .

**Exam tip:** In exams just show the steps (n,  $\phi$ , d, C, M). If your calculator cannot do large powers, use the square-and-multiply method shown above.

#### Q4(a) [3 marks] List and explain three web security threats.

★ Repeated topic - also asked in Winter 2025: Q4(a) (3M)

The web is a two-way network, so servers and browsers both face attacks. Threats are grouped by what they damage:

| Threat type              | Examples of threats                                                                                                   | Consequence                                                      | Countermeasure                          |
|--------------------------|-----------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|-----------------------------------------|
| <b>Integrity</b>         | Modification of user data; Trojan-horse browser; modification of memory; modification of messages in transit          | Loss of data, machine compromise, vulnerability to other threats | Cryptographic checksums (hash, MAC)     |
| <b>Confidentiality</b>   | Eavesdropping on the network; theft of info from server or client; info about network configuration; traffic analysis | Loss of information, loss of privacy                             | Encryption, web proxies                 |
| <b>Denial of Service</b> | Killing user threads; flooding with bogus requests; filling disk/memory; isolating machine by DNS attacks             | Disruption, prevents users from getting work done                | Difficult to prevent fully              |
| <b>Authentication</b>    | Impersonation of legitimate users; data forgery                                                                       | Misrepresentation of user, belief that false info is valid       | Cryptographic techniques (certificates) |

**Exam tip:** 3 marks 'three threats': write Integrity, Confidentiality and Denial of Service with one example line each. For the W2025 wording (integrity + confidentiality) use the first two rows in more detail.

#### Q4(b) [4 marks] Explain SSL protocol stack with diagram.

★ Repeated topic - also asked in Winter 2025: Q4(b) (4M)

|                     |                    |                |      |
|---------------------|--------------------|----------------|------|
| Handshake Protocol  | Change Cipher Spec | Alert Protocol | HTTP |
| SSL Record Protocol |                    |                |      |
| TCP                 |                    |                |      |
| IP                  |                    |                |      |

**SSL (Secure Socket Layer)** was developed by Netscape. It provides **confidentiality** and **message integrity** for TCP-based applications. SSL is a **two-layer** protocol:

- **SSL Record Protocol** (lower layer): provides basic security. Steps: *fragment* → *compress* → *add MAC* → *encrypt* → *add header*. Gives confidentiality (symmetric encryption) and integrity (MAC).
- **Handshake Protocol**: the most complex part. Client and server authenticate each other, negotiate the encryption algorithm, MAC algorithm and cryptographic keys. It runs in 4 phases: (1) hello messages, (2) server certificate and key exchange, (3) client certificate and key exchange, (4) change cipher suite and finish.
- **Change Cipher Spec Protocol**: a single message (value 1) that tells the other side to start using the newly agreed cipher keys.
- **Alert Protocol**: sends alert messages to the peer; each has a level (**warning** or **fatal**) and a code. Fatal alerts end the connection immediately.

**Session vs connection**: a *connection* is a temporary peer-to-peer link; a *session* is an association created by the Handshake protocol that can cover many connections (avoids repeating the expensive handshake).

#### Q4(c) [7 marks] Explain HTTPS connection initiation and closure.

★ Repeated topic - also asked in Winter 2025: Q4(b) OR (4M)

**Full forms**: **TLS** = Transport Layer Security; **HTTPS** = HyperText Transfer Protocol Secure (HTTP over SSL/TLS). HTTPS uses **port 443** and the URL starts with **https://**.

#### Connection initiation

In HTTPS the HTTP client also acts as the **TLS client**:



1. Client (browser) opens a TCP connection to the server on port 443.
2. TLS handshake begins: client sends **ClientHello** (supported ciphers); server replies with **ServerHello** and its **certificate**.
3. Client verifies the certificate, both sides exchange keys and agree on session keys, then send **Finished**.
4. Only after the TLS connection is established does the client send the **HTTP request**. The request and the reply travel inside TLS records, so URL, headers, cookies, form data and page content are all **encrypted**.

#### Connection closure

1. Either side can close the HTTPS connection. The HTTP header can say **Connection: close** to show the connection will be closed after the response.
2. Before closing the TCP connection, TLS sends a **close\_notify** alert so the other side knows that the closure is genuine.
3. Then the underlying **TCP connection is closed** (TCP FIN).
4. If TCP is closed **without** a close\_notify, a **truncation attack** may have happened - the client reports an error that data may have been cut off. The session can be resumed later using the saved session ID.

#### Q4(a) OR [3 marks] State functions of TLS record and TLS alert protocols.

- **TLS Record protocol** - gives two services: **confidentiality** (data is encrypted with a shared secret key) and **message integrity** (an HMAC is added to every record). It fragments data, optionally compresses it, adds the MAC, encrypts it and adds a header. Higher-layer protocols (Handshake, Alert, HTTP) all use it.

- **TLS Alert protocol** - carries TLS-related **alert messages** to the other side. Each alert has 2 bytes: **level** (warning = 1, fatal = 2) and **alert code**. A fatal alert (e.g. bad\_record\_mac, handshake\_failure) terminates the connection at once; a warning (e.g. close\_notify) lets it go on or closes it politely. Alerts are encrypted and compressed like normal data.

#### Q4(b) OR [4 marks] Differentiate SSL vs TLS.

| Point                  | SSL                                | TLS                                                        |
|------------------------|------------------------------------|------------------------------------------------------------|
| Full form / developer  | Secure Socket Layer - Netscape     | Transport Layer Security - IETF (RFC 2246)                 |
| Version                | SSL 3.0 (major version 3, minor 0) | TLS 1.0 = SSL 3.1 (and later TLS 1.2, 1.3)                 |
| Message authentication | Own MAC algorithm                  | <b>HMAC</b> (standard, stronger)                           |
| Key generation         | Ad-hoc method                      | Uses a <b>pseudo-random function (PRF)</b> based on HMAC   |
| Alert messages         | Fewer alert codes                  | More alert codes (e.g. decryption_failed, record_overflow) |
| Cipher suites          | Supports Fortezza                  | Fortezza removed                                           |
| Current status         | Deprecated / insecure              | In use (TLS 1.2 / 1.3 are standard today)                  |

#### Q4(c) OR [7 marks] Write short note on Secure Electronic Transactions (SET).

★ Repeated topic - also asked in Winter 2025: Q4(c) (7M)

**SET (Secure Electronic Transaction)** is an open protocol developed by **Visa and MasterCard (1996)** to protect **credit-card payments over the internet**. It uses digital certificates (X.509) and a **dual signature**.

##### Services provided

- Confidentiality of payment and order information.
- Integrity of all transmitted data.
- Authentication of cardholder and merchant (using certificates).
- Privacy: merchant sees only the order, bank sees only the payment.

##### Participants and their role

| Participant                  | Role                                                                                                                 |
|------------------------------|----------------------------------------------------------------------------------------------------------------------|
| Cardholder                   | Authorised holder of a payment card (customer). Places the order and pays.                                           |
| Merchant                     | Seller of goods/services; offers them for sale and accepts card payments (has certificates).                         |
| Issuer                       | Financial institution (bank) that issued the card to the cardholder; guarantees payment if the transaction is valid. |
| Acquirer                     | Merchant's bank; processes card authorisations and payments; gets money from the issuer.                             |
| Payment gateway              | Operated by the acquirer; links SET to the banking network; processes merchant's authorisation and payment messages. |
| Certification Authority (CA) | Trusted authority that issues X.509v3 certificates to cardholders, merchants and gateways.                           |

##### Sequence of events in a transaction

1. Customer **opens an account** with a card-issuing bank (e.g. a credit card).
2. Customer **receives a certificate** (digitally signed by the bank).
3. **Merchants have their own certificates** (one for signing and one for key exchange).
4. Customer **places an order**.

5. Merchant sends its certificate so the customer can **verify the merchant is valid**.
6. Customer sends **order and payment information**, with a **dual signature**: order info is readable only by the merchant, payment info only by the bank.
7. Merchant **requests payment authorisation** from the payment gateway.
8. Merchant **confirms the order** to the customer.
9. Merchant **ships the goods** or provides the service.
10. Merchant **requests payment** from the payment gateway.

#### Q5(a) [3 marks] List any three web security approaches.

★ Repeated topic - also asked in Winter 2025: Q4(a) OR (3M)

Web traffic security can be added at **three levels** of the protocol stack:

| Level                    | Protocol                   | How it works                                                                              | Pros / cons                                                                    |
|--------------------------|----------------------------|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| <b>Network level</b>     | IPsec                      | Security added at the IP layer; encrypts/authenticates all IP packets                     | Transparent to all applications; but needs OS/router support                   |
| <b>Transport level</b>   | SSL / TLS                  | Sits between TCP and the application; secures any TCP-based application (HTTP, FTP, SMTP) | Most common for web (HTTPS); built into browsers                               |
| <b>Application level</b> | SET, S/MIME, PGP, Kerberos | Security built into the particular application                                            | Can be tailored to the application's needs, but each application needs its own |

**Exam tip:** 3 marks: name the three levels with the protocol for each (IPsec, SSL/TLS, SET/S/MIME/PGP) and one line each.

#### Q5(b) [4 marks] State the role of IDS components: sensor, analyzer, user interface.

★ Repeated topic - also asked in Winter 2025: Q5(c) (7M)



| Component             | Role                                                                                                                                                                                           |
|-----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Sensor</b>         | Collects data from the network or host (packets, log files, system calls) and forwards it to the analyzer. Like the eyes of the IDS.                                                           |
| <b>Analyzer</b>       | Receives data from one or more sensors and <b>decides whether an intrusion has occurred</b> (using misuse or anomaly detection). May also suggest what action to take. Like the <i>brain</i> . |
| <b>User interface</b> | Lets the administrator <b>view the output</b> (alerts, reports) and <b>control the behaviour</b> of the IDS (set rules, thresholds). Like the <i>screen / control panel</i> .                  |

#### Q5(c) [7 marks] Explain working of Packet-filtering, Application Gateway, and Circuit-level Gateway firewalls.

★ Repeated topic - also asked in Winter 2025: Q5(c) OR (7M)

##### 1) Packet-filtering firewall (network layer)

Checks **each packet separately** against a set of rules (ACL) using header information: **source/destination IP address, port numbers, protocol (TCP/UDP/ICMP)**. Packet is **allowed or dropped** according to the first matching rule. It does not look at the data inside.

- **Advantages:** fast, cheap, transparent to users.

- **Disadvantages:** does not inspect payload; weak against IP spoofing; rules are hard to write; no user authentication; limited logging.

## 2) Application-level gateway / proxy firewall (application layer)

Works as a **proxy**. The user connects to the gateway, the gateway checks the request (user ID, command, content) and then makes a **separate connection to the real server** on the user's behalf. A separate proxy is needed for each application (HTTP, FTP, Telnet).

- **Advantages:** most secure; inspects application data; good logging; hides internal network.
- **Disadvantages:** slower (extra processing and two connections); one proxy per application.

## 3) Circuit-level gateway (transport layer)

Does **not inspect the data**. It sets up **two TCP connections**: one between itself and the inside user, and another between itself and the outside host. Once the connection is allowed (after checking handshake), it simply **relays the TCP segments** from one connection to the other. Example: SOCKS.

- **Advantages:** faster than application gateway; hides internal network.
- **Disadvantages:** no content filtering - once a circuit is allowed, anything can pass.

| Point     | Packet filter                     | Application gateway            | Circuit-level gateway |
|-----------|-----------------------------------|--------------------------------|-----------------------|
| OSI layer | Network                           | Application                    | Transport (session)   |
| Checks    | IP, port, protocol of each packet | Full application data and user | TCP connection set-up |
| Speed     | Fastest                           | Slowest                        | Medium                |
| Security  | Lowest                            | Highest                        | Medium                |

### Q5(a) OR [3 marks] Differentiate SSL and SET.

★ Repeated topic - also asked in Winter 2025: Q4(c) OR (7M)

How much to write: Write only the first three rows of the table.

| Point             | SSL                                                        | SET                                                                                    |
|-------------------|------------------------------------------------------------|----------------------------------------------------------------------------------------|
| Purpose           | General-purpose security for any TCP application           | Specially for <b>credit-card payments</b> on the web                                   |
| Layer             | Transport layer (between TCP and application)              | Application layer                                                                      |
| Authentication    | Server is authenticated; client authentication is optional | <b>All parties</b> (cardholder, merchant, gateway) are authenticated with certificates |
| Card details      | Merchant can see the card number                           | Merchant <b>never sees</b> the card number (dual signature)                            |
| Non-repudiation   | Not provided                                               | Provided (digital signatures)                                                          |
| Complexity / cost | Simple, built into browsers, easy to use                   | Complex, needs special software/wallet and certificates for all                        |
| Use today         | Very widely used (HTTPS)                                   | Rarely used now                                                                        |

**Exam tip:** For a 3-mark answer write only the first three rows (purpose, layer, authentication). For 7 marks write all rows.

### Q5(b) OR [4 marks] Compare NIDS and HIDS.

★ Repeated topic - also asked in Winter 2025: Q5(c) (7M)

| Point             | NIDS (Network IDS)                                   | HIDS (Host IDS)                                          |
|-------------------|------------------------------------------------------|----------------------------------------------------------|
| Placed            | On the network (at switch/router, a strategic point) | On an individual computer (host)                         |
| Monitors          | Network traffic / packets of the whole segment       | Logs, system calls, file changes, processes of that host |
| Coverage          | Many machines at once                                | Only one machine                                         |
| Encrypted traffic | Cannot inspect it                                    | Can see data after decryption on the host                |
| Installation      | One device can watch many hosts                      | Software must be installed on every host                 |
| Detects           | Port scans, DoS, network attacks                     | Insider misuse, malware, file tampering                  |
| Example           | Snort                                                | OSSEC, Tripwire                                          |

### Q5(c) OR [7 marks] Explain role and characteristics of firewall in system security.

★ Repeated topic - also asked in Winter 2025: Q5(b) (4M)

#### Characteristics (design goals)

1. **All traffic** from inside to outside and from outside to inside **must pass through the firewall** (all other access paths are blocked).
2. **Only authorised traffic**, as defined by the local security policy, is allowed to pass. Everything else is blocked.
3. The firewall itself is **immune to penetration** - it must run on a hardened, trusted system.

#### Techniques a firewall uses to enforce policy

- **Service control:** which services (HTTP, FTP, e-mail) can be accessed.
- **Direction control:** in which direction requests may flow.
- **User control:** which users are allowed to access which service.
- **Behaviour control:** how a service is used (e.g. filter spam).

#### Role in system security

- Acts as a **gatekeeper** / checkpoint between internal and external networks.
- Enforces the organisation's **security policy**.
- Provides a place for **monitoring and logging**; can host NAT and VPN.
- Protects internal systems from **external attacks** (scans, DoS, unauthorised access).

#### Limitations

- Cannot protect against attacks that **bypass** it (modem, Wi-Fi, USB).
- Cannot stop **insider** attacks.
- Cannot fully stop virus-infected files; wrong configuration creates holes.